

rs have background screenings and security awareness training. Certain background screenings can be facilitated by GitLab with the vendor's permission. Additionally, if the vendor lacks a security awareness training, propose that they incorporate the free security awareness training from the UK's National Cyber Security Centre.

- Does the vendor perform work from personal devices?
- Security requires that GitLab data is protected by adequate endpoint security controls.

</details>

TPRM Assessment Requirements

The following table defines the procedures followed by TPRM engineers for vendors accessing or being transmitted different classifications of GitLab data. The below procedures are initiated during the Procurement process and are followed in all instances where applicable vendors have not been reviewed within the approval windows defined below. Misalignment with TPRM's Minimum Security Standards may result in denial of a vendor requisition or issuance of a Security Notice. If a Security Notice was documented at the time of the previous assessment, inquiry will be performed prior to requisition approval to determine the current status of the identified deficiencies. Depending on the nature of the deficiency, a new TPRM assessment may be required. Any updates will be documented within the Security Notice Issue.

Data	Classification	Request	Supplemental	Questionnaire	Okta SSO?	New BIA	Tech Stack Entry?	Bitsight	Review?	Evidence of PenTest	and BCP Testing	
-----	-----	-----	-----	-----	-----	-----	-----	-----	-----	-----	-----	
Red	3rd Party Attestation	Yes	If applicable	Yes	If Applicable							
Yes												
Orange SaaS Systems or Locally Hosted/Installed Systems with Data Exchange	3rd Party Attestation	Yes	Yes	Yes	Yes	Yes						
Orange Individual Use Software	3rd Party Attestation or Self-Attestation	No	No	No								
Yes	No											
Orange Professional Services	3rd Party Attestation or Prof Svcs SIG	N/A	N/A									
N/A	N/A	N/A										
Yellow/Green	N/A	N/A	N/A	No	N/A	N/A						

Professional Services vendors utilizing a web-facing application to collect and store GitLab sensitive data are generally treated as an Orange SaaS system.

Procedures

Where GitLab controls, owns, or is otherwise responsible for data, the diagram below depicts TPRM procedures based on the Data Classification of data shared with the third party.

{{% details summary="(Expand to view chart)" %}}

mermaid

graph TB
%% Define all required nodes
%% Procurement Intake Channels
ProcIntake[Purchase Request Created]

%% Determining Data Class

```
zgClass{Data Classification}
  zgGreen[Green]:::Green
  zgYellow[Yellow]:::Yellow
  zgOR[Orange]:::Orange
  zgRed[Red]:::Red
```

%% Data Classification Specific Procedures

%% Green

```
zgGApprov[Security Approves]:::Green
```

%% Yellow

```
zgYApprov[Security Approves]:::Green
```

%% Orange

```
zgAssess{Third Party Security<br>Assessment Begins}
  zgQuest[Security Questionnaire Sent]
  zgTPResponse[Third Party Responds]
  zgReview[Security Reviews]
  zgMeets{Response Satisfies<br>GitLab Standards?}
    zgMeetsNo[No]
    zgMeetsYes[Yes]
    zgFup[Follow-up Required]
  zgIssues{Issues Identified}
    zgIssueY{Yes}
    zgIssueN[No]
    zgAccept[Business Owner Accepts Risk]
    zgStop[Business Owner Chooses<br>Not to Work with Third Party]
  zgORApprov[Security Approves]:::Green
```

%% Red

%% Linking nodes together

```
ProcIntake-->zgClass
```

```
zgClass --> zgGreen
```

```
zgClass --> zgYellow
```

```
zgClass --> zgOR
```

```
zgClass--> zgRed
```

```
zgGreen --> zgGApprov
```

```
zgYellow --> zgYApprov
```

```
zgRed --> zgAssess
```

```
zgOR --> zgAssess
```

```
zgAssess --> zgQuest --> zgTPResponse --> zgReview --> zgMeets
```

```
zgMeets --> zgMeetsNo --> zgFup --> zgQuest
```

```
zgMeets --> zgMeetsYes --> zgIssues
```

```
zgIssues --> zgIssueY
```

```
zgIssueY --> zgAccept --> zgORApprov
```

```
zglIssueY --> zgStop
zglIssues --> zglIssueN --> zgORApprov
```

%% Clickable Nodes

click ProcIntake "https://handbook.gitlab.com/handbook/business-technology/enterprise-applications/guides/zip-guide/how-to-initiate-a-new-request" blank

%% Dedicated styling

```
%% classDef clickme fill:6E49CB,stroke:88DDFD,stroke-width:4px,color:FFFFFF;
classDef Green fill:A3CC6C,stroke:A3CC6C,color:000000;
classDef Yellow fill:F9FF33,stroke:F9FF33,color:000000;
classDef Red fill:DB3B21,stroke:DB3B21,color:000000;
classDef Orange fill:FFA500,stroke:FFA500,color:000000;
classDef empty opacity:0
```

{{% /details %}}

Determining Vendor Inherent and Residual Risk

TPRM procedures are guided by the vendor's Inherent and Residual Risk levels, which are determined based on the services provided and the nature of data shared. An understanding of these risks is crucial in making an informed business decision for leveraging a vendor.

Inherent Risk is the vendor's baseline risk level before accounting for mitigating controls required by GitLab's Third Party Risk Management Program. GitLab uses the sensitivity of the data exchanged with the vendor to establish the baseline risk level, which dictates our TPRM assessment requirements

|Inherent Risk Level|Data Classification|

|:-----:|:-----:|

|Critical|Red|

|High|Orange SaaS¹|

|Medium|Orange²|

|Low|Yellow / Green|

 <i> Due to increased risk with vendor engagements providing cloud services (such as SaaS offerings), the inherent risk level has been elevated to account for emerging threats and vulnerabilities associated with these types of services. </i>

<i>Orange Individual-Use Software is assessed as medium inherent risk under a reduced scope due to the decreased risk associated with these types of requests. See here for further guidance.</i>

Residual Risk is the level of risk that remains after accounting for mitigating controls required by GitLab's Third Party Risk Management Program. Effectively managing vendor residual risk requires a balanced approach that considers the criticality of the vendor's services or products, the sensitivity of the data involved, and GitLab's risk tolerance.

Vendors that meet GitLab's security requirements will have residual risks levels as follows:

Inherent Risk Level	Residual Risk Level
:-----: :-----:	
Critical High	
High Medium	
Medium Low	
Low Low	

Vendors that fail to meet GitLab's Third Party Risk Assessment requirements will have a residual risk score equivalent to the inherent risk score and may require a Security Notice.

Third Party Minimum Security Standards

TPRM utilizes a risk-based approach when assessing third parties. Specific procedures used to assess different vendor types / risk profiles can be found within the TPRM Assessment Requirements section above.

The Security Risk Team will take reasonable steps to collaborate with vendors and obtain the documentation necessary to complete our review. Depending on the service provided and the data being transmitted, this may include requests for a Third Party Security Attestation and other relevant documentation such as a penetration testing summary and business continuity plan test. In the event that a vendor does not maintain this documentation, or refuses to provide it, the Security Risk team may deny the request or require completion of a TPRM Security Notice prior to approval.

Deficiencies commonly identified during our TPRM procedures are listed below:

1. Lack of third-party Security attestation such as an ISO 27001, SOC2 Type 2
1. Lack of background checks for employees and contractors
1. Inability to integrate with Okta (in alignment with GitLab's Password Standard)
 - If the Okta integration is not in place or not possible, native multi-factor authentication (MFA) capabilities can be a mitigating control.
1. Systems lacking evidence of a recent penetration test
1. Unresolved deficiencies documented within the penetration test with no apparent remediation plan or expected remediation date
 - Penetration testing findings are reviewed by the engineer to understand the nature of the deficiency and their impact to GitLab. Deficiencies found to present a negligible impact to GitLab or that are sufficiently mitigated by existing GitLab controls may not result in an adverse conclusion.

While Okta SSO integration is GitLab's preferred method of authentication, IT Engineering can review and approve alternative SSO methods (such as Google OAuth) on a case by case basis.

Deficiencies identified are reviewed in the context of the vendor's greater Security environment and the data transmitted. If a material risk to GitLab data is identified, this will be reported to the Business Owner via the TPRM Security Notice Process.

Acceptable Third-Party Attestations

GitLab obtains and reviews third-party attestations to provide assurance over the design and operating effectiveness of a service provider's internal control environment. These attestations commonly include, but are not limited to, an ISO 27001 certificate or a Service Organization Control (SOC) 2 Type 2 report. Alternate forms of attestations can be leveraged in the absence of these more common documents, though diligence should be performed by the assessor in determining whether the attestation provides sufficient coverage over the control environment and aligns with our assessment criteria.

ISO 27001: An ISO 27001 certificate with the accompanying Information Security Management System (ISMS) scope and Statement of Applicability (SoA) can be leveraged as evidence of compliance with industry-standard security best practices. The ISMS scope helps ensure that the services provided by the vendor to GitLab are covered by the ISO audit, and the SoA provides visibility into the policies and controls that are applied by the organization. A valid ISO 27001 certificate providing coverage over applicable services indicates that an external certifying body has performed testing to validate the design and operating effectiveness of controls related to the management team's continued performance of the following:

- Systematic examination of the organization's information security risks, taking account of the threats, vulnerabilities, and impacts;
 - Design and implementation of a coherent and comprehensive suite of information security controls and/or other forms of risk treatment (such as risk avoidance or risk transfer) to address those risks that are deemed unacceptable; and
 - Adoption of an overarching management process to ensure that the information security controls continue to meet the organization's information security needs on an ongoing basis.
- (Source)

In the event that a vendor provides a valid ISO 27001 certificate but is unable to provide their SoA and ISMS scoping document, we require the completion of a self-attestation such as a SIG or CAIQ to meet our assessment criteria and gain a better understanding of their security environment.

Be aware that ISO 27001 certificates include an expiration date. Once this date has passed, the certificate is no longer valid and should not be leveraged in our assessment.

SOC 2 Type 2: The SOC 2 Type 2 report is the preferred attestation when assessing third party risk, as this report details the design of an organization's information system and how various forms of risk are addressed. This report not only details the controls in place within an organization, but it also includes independent validation of whether or not each of those controls functioned effectively during the audit period. This report should be reviewed to validate the following:

- The report provides coverage over the service being provided to GitLab;
- The report was issued within the last 12 months;
 - If the most recent report is older than 12 months, a Bridge Letter should be obtained to provide assurance that material changes have not occurred to the vendor's control environment since the report's issuance.
- The report is issued without a qualified opinion or exceptions otherwise impacting the security of GitLab data.
 - A report designated as "qualified" indicates that one or more controls assessed were found to be inadequately designed or implemented during the audit period. The nature of the

qualification should be reviewed and understood to determine whether the control failure could impact the security of GitLab data, and if so should be reported to the Business Owner via TPRM Security Notice.

- Exceptions may be identified within the report that do not result in the issuance of a qualified opinion, though any exceptions should still be reviewed for the following to determine if they may present a risk to GitLab data:

- Nature of the Exception: The related control and the exception itself should be reviewed to determine whether GitLab relies upon that control to safeguard our data.

- Management's Response: A management response is often included to address the reason for the exception and any steps that have been taken to address and remediate it. This may be accompanied by re-testing performed by the external auditor to validate that remediation was successful.

- These items, if present, should be noted within the TPRM Assessment Report. If the nature of the qualification or exception is found to impact GitLab's security, and management's response provides insufficient assurance that remediation steps have been taken, this should be reported to the Business Owner via the TPRM Security Notice Process.

SOC 2 Type 1: The SOC 2 Type 1 report is often published as part of a preliminary assessment during the SOC 2 Type 2 "readiness" process. This is a limited scope, point in time assessment of the design of controls in place within a service provider's environment, and does not include a validation of control operating effectiveness. As such, the Type 1 report should not be leveraged on its own to address our third-party attestation requirements for Orange SaaS / Red systems, however it may be leveraged in addition to an ISO 27001 certificate or equivalent attestation in providing assurance over a service provider's environment.

PCI Attestation of Compliance: A PCI Attestation of Compliance (AoC) is leveraged by the Security Compliance Team to validate a service provider's compliance with the PCI DSS framework. This attestation, along with the accompanying Responsibility Matrix, is commonly required for vendors hosting GitLab infrastructure. The Security Risk team gathers this documentation when necessary to support the Security System Intake process. PCI AoCs are not leveraged by Security Risk to meet TPRM Assessment Requirements.

Complementary User Entity Controls (CUECs)

Some vendor's control objectives cannot be met without proper design and implementation of supporting controls by GitLab, which are specified in the form of Complementary User Entity Controls (CUECs) within a vendor's SOC 2 report. CUECs are commonly leveraged by vendors to support data security and service commitments, and it is GitLab's responsibility to address these controls to support data security and prevent unauthorized data disclosure.

The Security Risk team obtains vendor SOC 2 reports during our reviews and determines whether CUECs are defined and relied upon by the vendor. If CUECs are defined, the Business Owner will be notified upon approval of the Zip requisition and instructed to review the CUECs and ensure controls are in place to address them. If controls are not already in place, the Business Owner is responsible for coordinating the implementation of these controls. This can be completed in collaboration with the Security Assurance team. We recommend creating an epic in your primary GitLab project titled Application/Service Name CUEC Mapping. An issue should be created for each CUEC that requires action. Issues would be closed once a documented plan or process is in place, ideally in the Handbook, including a mechanism for ensuring the controls take place periodically if needed. Common CUECs and guidance for each can be found in the table below.

Note that the specific language defined in the vendor's SOC report may differ from the language below and may require a modified course of action.

{{% details summary="(Expand to view chart)" %}}

| | CUEC | Guidance | Related GCF Control(s) |

|---|:----|:-----| -----|

[1]Ensuring accuracy of data shared with vendor|We should reduce the risk of data quality problems which can arise when moving data from one system to another. This can be done by comparing source data to destination data. Queries used to generate the data should be reviewed to ensure things aren't filtered out inappropriately.| SC-8 |

[2]Adding and removing access to the application|For new applications, the Tech Stack Add process should facilitate on-boarding applications into our access request and off-boarding processes. For existing applications, ensure that the processes mentioned above are followed for your application.| AC-2|

[3]Controlling access to our network|We don't have a traditional enterprise network. Integrating with Okta should help ensure access to the application is gated behind multi-factor authentication and is accessible only through Okta.|AC-17|

[4]Reviewing access to the application|Access Reviews for Tier 1 and Tier 2 systems that are in scope for our compliance and regulatory programs. System owners of Tier 1/2/3 systems that are not in scope for our compliance and regulatory program are highly encouraged to perform a minimum of an annual terminated access review for their owned systems using this process as a guide. Access reviews for Tier 4 systems are not required. To request an ad-hoc access review, create a request issue here. Reminders of the periodic review can be set up as Google Calendar events on a shared calendar or an issue can be created on scheduled pipeline in GitLab.| AC-6 |

[5]Notify vendor of changes timely|Work with the vendor to understand which changes need to be communicated. A common instance is when someone leaves a company that was considered a primary or secondary point of contact for the vendor or in the event of a security breach. Establish a process for documenting these scenarios, how they're communicated, and SLAs for doing so.| SR-8 |

[6]Establishing disaster recovery procedures|We should be prepared for an outage of the application. Would we be able to reproduce the data that isn't available due to the outage? Document a procedure for how we would respond to an outage of an application.| CP-2 |

{{% /details %}}

Questions regarding CUECs can be directed to the sec-assurance channel in Slack.

Standard Information Gathering (SIG) Questionnaire for Vendor Self Attestation

A self-attestation such as a SIG questionnaire, or equivalent document such as a CAIQ, is required if an individual-use software vendor is unable to provide a valid SOC 2 Type 2 report or an ISO 27001 certificate along with its Statement of Applicability and ISMS scoping document. Red vendors or Orange SaaS vendors are required to provide a Third-Party Attestation as defined above. The SIG questionnaire is reviewed alongside the responses to our Security Questionnaire when assessing the maturity of a service organization's Security environment.

Security Risk maintains multiple templated versions of the SIG questionnaire for use depending on the product or service being assessed, as some vendors may not have a SIG questionnaire or equivalent to provide. The SIG templates include instructions noting that we only require

Inquiry responses within Columns D and E of the main questionnaire tab, as additional requests for information or documentation within the SIG are generally not required. Note that potential fringe cases could exist wherein professional discretion may dictate the necessity for additional documentation requests to supplement vendor responses. Further, professional discretion should be applied when making decisions as to which version of the SIG questionnaire should be sent. For cases in which the level of review required is unclear, engineers are encouraged to discuss with the @Security-Risk team in the Sec-Assurance-Team channel to come to a decision considering factors such as the services offered, data exchanged and the outcome of previous assessments.

{{% details summary="SIG Lite Plus" %}}

- SIG Lite Plus

- The SIG Lite Plus questionnaire is leveraged most commonly and should be utilized for all Red vendors and Orange SaaS systems. We refer to our SIG Lite as the "SIG Lite Plus" as it includes full scope SIG questionnaires for domains "E. Human Resource Security and V. Cloud Services". All other domains include standard SIG Lite content. Our objective here is to obtain additional information related to cloud security and the use of personal computers and employee background checks.

- The following 20 domains are included within the scope of the SIG Lite Plus questionnaire:

- A. Enterprise Risk Management
- B. Nth Party Management
- C. Information Assurance
- D. Asset and Info Management
- E. Human Resources Security (Full SIG Content)
- F. Physical and Environmental Security
- G. IT Operations Management
- H. Access Control
- I. Application Management
- J. Cybersecurity Incident Mgmt
- K. Operational Resilience
- L. Compliance Management
- M. Endpoint Security
- N. Network Security
- O. Environmental, Social, Governance (ESG)
- P. Privacy Management
- R. Artificial Intelligence
- S. Supply Chain Risk Mgmt
- T. Threat Management
- U. Server Security
- V. Cloud Services (Full SIG Content)

{{% /details %}}

{{% details summary="Professional Services SIG" %}}

- SIG Professional Services

- The Professional Services SIG Lite Plus questionnaire features a reduced scope and can be leveraged for scenarios in which an Orange vendor is only providing contracted services or services not otherwise resulting in the introduction of a system being transmitted sensitive GitLab data. In these cases it may not be necessary to perform a full-scope review of the

vendor's Security environment, as many controls within the full SIG Lite questionnaire may not apply or present a material risk to GitLab data. Please note this guidance applies only to Orange professional services providers. Service providers being granted access to Red data in the provision of services should be assessed utilizing the SIG Lite Plus questionnaire defined above due to the greater obligation for Data Security with these providers.

- The following domains are included within the scope of the Professional Services SIG Lite Plus questionnaire.

- D. Asset and Info Management
- E. Human Resources Security (Full SIG Content)
- F. Physical and Environmental
- H. Access Control
- L. Compliance Management
- M. Endpoint Device Security
- N. Network Security
- P. Privacy Management
- T. Threat Management

{{% /details %}}

{{% details summary="Reviewing SIG Responses" %}}

Vendor responses documented within the SIG questionnaire should be reviewed in the context of the services provided by the vendor, with care taken to understand the broader control environment and how certain control deficiencies may be mitigated by other existing controls. For example, a vendor that does not rely on 3rd party service providers in the provision of services would be unlikely to maintain a Third Party Risk Management program, which is unlikely to pose a risk to GitLab in the broader context of services being provided. Significant deviations such as this should be flagged during the review and noted within the SIG questionnaire with an explanation on why the deficiency does not present a risk to GitLab data. Mitigating controls, if identified, should be defined within these notes as well. Engineers are encouraged to perform follow-up inquiries with vendors as necessary to determine whether a control deficiency exists. These inquiries should be further noted within the SIG document or within the TPRM Assessment Report.

Deficiencies identified that may present a material risk to GitLab data should be noted within the TPRM assessment report and presented to the Business Owner via the TPRM Security Notice Process detailed below.

SIG questionnaires (or equivalent) provided by a vendor not utilizing a GitLab-provided template should be reviewed to ensure they meet our due diligence standards. Domains not sufficiently addressed by a vendor-provided questionnaire should be identified, with additional inquiries performed to gain assurance over all in-scope domains.

{{% /details %}}

Leveraging Bitsight

Usage of Bitsight provides the Security Risk team with a comprehensive and continuous view of the external security posture of GitLab's vendor ecosystem. Bitsight enables Security Risk to identify and assess potential security risks across our vendors in real-time, allowing us to prioritize our resources and focus on addressing the potentially critical vulnerabilities that could impact GitLab. GitLab leverages two services:

- Bitsight Total Risk Monitoring

Bitsight's Total Risk Monitoring is leveraged to obtain additional assurance over the security of a vendor's externally accessible environment by use of public scans and peer benchmarking. When assessing a vendor, their Bitsight report is downloaded and reviewed to determine whether their scoring is adequate, as evidenced by an "Advanced" security rating. Bitsight ratings of "Basic" or "Intermediate" are reviewed in further depth to understand the rationale behind the lower rating and whether the deficiencies identified may indicate a risk to GitLab. Due to the wide scope of Bitsight's scans, some deficiencies may exist within areas that do not impact GitLab's usage of a vendor's service(s), and thus do not contribute to the vendor's residual risk. If deficiencies are identified that may present a material risk to GitLab, further inquiry may be performed with the vendor to determine whether they have been resolved. Unresolved material deficiencies should be documented within the TPRM Assessment Report and reported to the Business Owner via the TPRM Security Notice Process defined below.

If a vendor is not available in Bitsight, the assessor should submit a Company Request within BitSight. We can leverage their penetration testing report and relevant SOC 2 controls for assurance if the request cannot be fulfilled in time to support the assessment. If BitSight is able to add the vendor, the results should be added to the TPRM review which triggered the request.

- Bitsight Daily Alerting

Bitsight's Daily Alerting is leveraged to establish a system for continuously monitoring the security posture of GitLab's highest criticality vendors to identify and respond to potential risks and vulnerabilities promptly. The use of this service enables Security Risk to maintain a proactive approach to third party security management, operating 24/7 to help safeguard GitLab sensitive data and infrastructure effectively. Changes in GitLab's Tier 1 vendor's environments could lead to further security inquiries and investigations, a new security review, or TPRM Security Notice, depending on the severity and impact to GitLab.

TPRM Approval Windows

The Security Risk team has established approval windows dictating the lifecycle of our TPRM assessments and their reliance in approving requisitions, after which a new assessment must be completed prior to approval of subsequent requisitions to ensure continued adherence to GitLab's regulatory and due diligence requirements. These windows are defined in alignment with the sensitivity of data shared and the nature of the associated requisition.

- Red and Orange Vendors: Tier 1 - 3 vendors being transmitted Red or Orange data are subject to a 12-month approval window from the previous assessment, with the exception of Low Risk Orange Vendors defined below.
- Low-Risk Orange Vendors: Tier 4 Vendors and those receiving Orange data elements limited to GitLab Team Member physical addresses and phone numbers are subject to a 24-month approval window. An example may be a SWAG provider that receives GitLab employee names and addresses for the purposes of delivering shipments. The transmission of this type of GitLab Team Member personal data presents a low level of risk and does not present a Security Risk that could impact GitLab customers.

Requisitions must be reviewed to determine whether a scope change has occurred since the

previous assessment that could indicate a material change in the data transmitted to the vendor. See the Material Changes section for guidance.

Material Changes

Material Changes to services provided to GitLab or to a vendor's security environment could present an increased risk that may not have been present at the time of the previous review. As such, requisitions for vendors within the Approval Window of their previous assessment must be reviewed by the TPRM Engineer to determine whether a material change has occurred to the service(s) provided. Examples of these changes include:

1. Change in data classification, such as going from Yellow to Orange data classification.
1. Addition of a new system not in the scope of the previous review. For example, vendor XYZ was reviewed for procurement of their Billing system, but a new request has come in for the purchase of their Revenue system.
1. Change of location where data is stored or transmitted, such as migrating data from a GitLab-hosted environment to a vendor's SaaS solution.
1. Addition of new contractors that are not subject to the vendor's security controls.
1. Introduction of new AI functionality within a system resulting in the addition of a new sub-processor.

To determine whether the previous review provides assurance over the new service or system, review the previously-leveraged documentation for coverage or ask the vendor directly. If sufficient assurance does not exist, or the change is believed to introduce additional risk to GitLab, the Security Risk team may need to complete a new TPRM review prior to approving the requisition.

Vendors occasionally implement changes between contracting cycles that could introduce previously unidentified risks, such as the introduction of new AI features and/or subservice providers. Team members should notify the Security Risk team when these changes occur, and if necessary may be directed not to allow, utilize, or enable such functionality until a new assessment has been completed. Upon notification of such changes, the Security Risk team will follow the above procedures to determine whether a new review is necessary.

Note: Circumstances may exist outside of those defined above that could necessitate further review. TPRM Engineers should use professional discretion in identifying these circumstances and perform additional review or validation as needed. Questions or concerns regarding the materiality of a change or the appropriate approval window should be escalated to the Security Risk Team within the Sec-Assurance-Team channel.

TPRM Security Notice Process

Deficiencies identified during a TPRM review are reported to the Business Owner via a TPRM Security Notice within GitLab. This issue contains (1) background information pertinent to the vendor or requisition, (2) a description of the validations performed by the Security Risk team, and (3) a description of Security deficiencies and resulting risk that may be present to GitLab data shared with the vendor. A "worst case" scenario is included to portray the potential real-world impact of a security incident resulting from the risk. Where possible, TPRM will also include a recommendation for either mitigating or avoiding the identified risk. For deficiencies resulting from a failure in the design or operating effectiveness of a

system's Security controls, a Technical Security Validation may be requested prior to stakeholder delivery to provide greater context within the Security Notice. These items are documented in order to support an informed decision by the Business Owner and other relevant parties.

Requisition Denial

TPRM may deny requisitions in the event that we are unable to obtain sufficient assurance over a vendor's security environment or if there are deficiencies presenting an active risk to GitLab data or service offerings.

New vendors unable to meet our minimum security requirements may be denied by Security. If you have concerns that a prospective vendor may not meet our requirements please reach out to @securityrisk in Slack.

Existing vendors not meeting our minimum security standards may require documentation of an offboarding plan or a remediation plan agreed upon by the vendor prior to requisition approval. The Security Notice will be routed for approval as documented below.

TPRM does not maintain a listing of denied third parties as their environments are subject to change and may mature to meet our requirements. Previous assessment outcomes are documented and available upon request.

Accepting the Risk

Circumstances may arise in which business requirements necessitate moving forward with a vendor. In these scenarios the Business Owner and other relevant stakeholders may elect to accept the documented risk as not to negatively impact business operations. Security Risk will provide their opinion regarding whether or not this is warranted based upon the information available. If the Business Owner decides to move forward with the vendor in light of the reported deficiencies, they are responsible for completion of the below items:

1. Acknowledgement of the Accept the Risk section of the StORM handbook page and their understanding of its contents.
1. Justification for moving forward with the vendor in light of the identified deficiencies.
1. Remediation Plan to address any identified deficiencies. This must be time-bound and include all necessary steps to resolve the Security finding. Failure to remediate the finding prior to the next renewal may result in E-Group escalation.
1. Annual recertification in the event that the risk is unremediated. This will trigger a new assessment of the vendor or system along with associated approvals from relevant stakeholders.
1. Approval of the Security Notice. In order to promote transparency across the organization, approval will be required by the Business Owner, their VP, IT, and the appropriate E-Group member if deemed necessary by the Security Risk team based on the perceived severity of the deficiency.

In some circumstances, the business may require accelerated approval of a requisition prior to completion of a security review. In these scenarios, a TPRM Security Notice will be documented and presented to the Business Owner and their VP. Failure to obtain the requisite materials within a reasonable timeline following approval may result in escalation of the risk to the E-Group.

Scenarios could exist in which a Security control failure carries Privacy implications that should be communicated to the Business Owner. As such, the Privacy team should be notified prior to finalization of the associated Security Notice.

Technical Security Validations

TPRM partners with GitLab's Security Research team to facilitate Technical Security Validations (TSVs) of higher risk systems such as those affected by deficiencies in the design or operation of their security controls. These validations are triggered during our Security Notice process and include a deeper look into the security configurations of a system and their impact to GitLab. Necessity of a TSV is determined based on the nature of deficiencies identified, nature of data transmitted, and criticality of the system. Areas of concern identified during the TSV process are documented within the TSV issue and integrated into the related Security Notice to provide greater assurance to GitLab and support informed decisions by stakeholders.

Completion of the TSV may be required at TPRMs discretion prior to approval of the associated requisition, depending on factors such as severity of the identified deficiency, sensitivity of data transmitted, and criticality of the system. This approach is taken to facilitate a more informed business decision prior to the introduction or continued presence of data within potentially insecure environments. The Business Owner will be notified of this and can appeal the delay if it may cause a business disruption or lapse in payment to the vendor.

Tech Stack Additions and New System Onboarding

As an output of our TPRM assessments, the Security Risk team partners with Information Technology to inventory the usage, administration, and integration of new applications supporting various GitLab functions. This inventory lives within the Tech Stack, GitLab's single source of truth (SSOT) for technology that supports the business.

The Security Risk team facilitates multiple functions to maintain accuracy of Tech Stack data, including Critical System Tiers. This data is leveraged to ensure critical applications are appropriately supported. Functions consist of:

- Merge Requests upon system procurement to update the Tech Stack.
- Initial Business Impact Analyses (BIA) to help determine the systems critical to serving GitLab's Customers.
- Recurring procedures to validate the accuracy of existing Tech Stack data, including an annual Business Impact Analysis for Tier 1 Systems.
- Design and maintenance of a Post-Implementation Checklist to help ensure Business Owners implement security best practices during and after new system onboarding

More information on how Critical System Tiering is leveraged in support of GitLab can be found within the StORM Handbook page.

Other Types of Third Party Assessments

Annual High-Risk Vendor Assessments

GitLab places particular reliance on a subset of vendors that either have access to Red data or are in scope for compliance activities. With this in mind, Security Risk follows an annual

assessment cadence for these vendors to ensure ongoing coverage and identification of potential security risks. This is scheduled to take place between late-Q3 and Q4 of each Fiscal Year.

Scoping for this activity is based on the below populations, and is finalized in coordination with various teams within GitLab to ensure accuracy in our scoping:

- 1. GitLab's Third Party Sub-Processors
 - 1. Red Professional Services Sub-Processors
 - 1. SOC 2-scoped Applications
 - 1. Red Applications

Vendors within the above populations are assessed in alignment with our Red vendor assessment criteria. Deficiencies identified are reported to Business Owners in alignment with our TPRM Security Notice process.

Is there a vendor you'd like to see included in our annual assessment procedures? Reach out to @Security-Risk in the Sec-Assurance channel.

Change Requests

Change requests relating to previously-approved requisitions will be reviewed by the on-call Engineer to determine whether a material change is being requested to the scope of services or the timeframe of the services provided. Changes requested specific to the cost of services and that do not present a material change impacting Security can be approved based on inheritance of approval from the parent requisition.

For example: We performed a TPRM assessment for Vendor X which was completed on December 31, 2021, resulting in a 12 month coverage period lasting to December 31, 2022. A change request was created in January 2023 (outside of coverage period) related to overage charges for services provided during November 2022 (within coverage period). This example change request can be approved without a new TPRM assessment.

Engineers are advised to use professional judgment in determining the scope of changes and are encouraged to perform additional review prior to approving the Change Request if there is potential for introduction of additional risk. For other non-material adjustments not defined here that may not warrant additional review, Engineers should ping the Security Risk team or discuss with the Security Risk Manager prior to moving forward to ensure alignment with GitLab's due diligence requirements. Rationale should be documented when approving the Change Order in alignment with the low-risk approval language in the TPRM README.

Third Party Application Integrations

Integrations between systems within GitLab's environment are subject to the above-defined TPRM assessment procedures to obtain assurance over the security of data transmitted between each system. The Security Risk team will review the request to obtain an understanding of the data being shared. Application Integration Requests can be opened using the App Integrations issue template located [here](#).

The Application Integration Request process functions to allow visibility and oversight of systems interacting with each other in support of GitLab. This process also functions as a

"soft gate" for the Security Risk team to identify and assess existing systems that have aged out of their approval window. Each system within the integration request is reviewed to determine whether an assessment has previously been completed to address the sensitivity of data being transmitted as a result of the proposed integration. New systems, or integrations resulting in increased sensitivity of data being transmitted to a system, will require a TPRM review be completed prior to approval of the request. If each system listed within the request has been previously assessed at any point in alignment with the data shared in the new integration, the request can be approved prior to additional review.

If the review for either system in question has aged out of its approval window, the request can be approved with a new review of either system being launched and completed afterwards. This is intended to support GitLab's values of Iteration and Results by not delaying integrations that we believe to be of lower risk. If our review criteria have been met, but areas of concern have otherwise been identified, assessors are encouraged to use professional judgment in not approving the request until the items are resolved or until a new assessment has been completed. Deficiencies identified as a result of Application Integration Requests are reported to the Business Owner of the related system, which may or may not be the individual that opened the Integration Request.

Individual-Use Software Requests

GitLab Team Members leverage Individual Use Software for various tasks on a user-by-user basis. Generally, these tools are categorized as having a Critical System Tier of '4'. Because Individual Use Software does not have a technical and/or Business Owner, it is not required to be represented in the Tech Stack. Security Risk reserves the right to disallow or not approve the use of Individual Use Software that does not meet GitLab Security requirements. Exceptions to this process will be considered on a case-by-case basis and reported to relevant stakeholders via the TPRM Security Notice process. For more information, refer to GitLab's Internal Acceptable Use Policy.

Commonly requested individual-use software is added to the Pre-Approved Application Listing located [here](#). This listing is used to document approved vendors, their data classification, and the expiration of their most recent TPRM assessment where applicable. Assessments that have aged out are re-performed on an ad-hoc basis or upon entry of a new procurement request.

Orange Individual-Use Software is assessed under a reduced scope in consideration of vendor resourcing and the limited scope of usage within GitLab. See the TPRM Assessment Requirements section above for more detail on requirements for these vendors. Assessors are encouraged to perform a full-scope assessment if they feel one is warranted.

Independent Assessments

Want to vet a third party before initiating a new procurement request? [Click here](#) to open a new Third Party Risk Intake Request.

Documentation Requests

Looking for compliance reports for an active GitLab vendor? Open a new issue within the TPRM workspace using the 'Vendor Documentation Request' template, and we'll be happy to track it down.

Usage of Artificial Intelligence (AI)

Usage of Artificial Intelligence (AI) services by GitLab Team Members carries unique Security, Privacy, and Legal implications and is governed by GitLab's Acceptable Use Policy. While TPRM has integrated procedures to gain assurance over the security of AI functionality, we may be unable to make determinations in some scenarios as to whether usage of these services is in alignment with GitLab's AI Acceptable Use Policy. As such, TPRM may engage the Legal and CorpSec teams prior to requisition approval to understand whether the usage of this functionality could result in additional risks. Adverse findings by these teams may result in denial of the requisition by the TPRM Engineer.

Exceptions to the TPRM Process

In specific instances, requirements for the performance or contents of TPRM reviews may vary from the standard process defined above:

1. For privacy-driven TPRM reviews, instances where GitLab receives personal data from a third party in a Controller-to-Controller transfer do not require a TPRM review. The Privacy team will classify the nature of the relationship as part of the Privacy assessment during the procurement process.

1. Law Firms, Accountants and Auditors may receive data, including Red data, in a Controller-to-Controller relationship, meaning these types of entities have direct obligations and standards for processing data under law. As such, these entities may be treated as Orange vendors.

1. Instances where GitLab Team Members provide their own data to a third-party Data Controller, in which the Team Member personally acknowledges the third-party's terms, may not require a TPRM assessment. Examples may include signing up for health, coaching or counseling benefits where GitLab only finances the service but does not send or receive data on behalf of Team Members and Team Members voluntarily decide to enter the program.

1. Field Marketing events do not require the completion of a Security review as the gathering of contact information for GL Team Members and prospects is considered to be standard for the normal course of business for the Field Marketing team. Note that if the Field Marketing Team is commissioning the use of software to facilitate its operations or have hired a Vendor to collect data on behalf of GitLab, these vendors may be subject to TPRM review as they could be considered a Data Processor(see 1. above for more information). GitLab receiving event data from another organizer or GitLab sharing event data with other independent organizations and/or sponsors does not require a TPRM assessment.

References

- GCF Compliance Controls
- Data Classification Standard
- Current listing of controlled documents
- App Integrations (Team Member Enablement)
- Observation Management Procedure
- STORM
- Procurement Process

SECTION: security/security-assurance/security-risk/storm-program/_index.md

{{% panel header="Not a GitLab team member but want to provide feedback on our StORM program?" header-bg="primary" %}}

We receive feedback from GitLab team members regularly and we wanted to provide a mechanism for non-GitLab team members to provide feedback as well to help us iterate and align more closely with our values. If you are not a GitLab team member and would like to provide feedback on our Security Operational Risk Management (StORM) program or methodology, please use this feedback form to submit anonymous feedback.

{{% /panel %}}

Purpose

The purpose of the Security Operational Risk Management ("StORM") program at GitLab is to enable better decision-making by identifying, monitoring, treating, and reporting on security operational risks in support of GitLab's strategy. The Security Risk Team utilizes the procedures below (formed through consideration of guidance set forth in NIST's SP 800-39, SP 800-30 Rev. 1, and ISO 31000 Risk Management Methodology) to ensure that security risks that may impact GitLab are effectively managed.

Scope

The scope of the StORM program is limited to operational, technology-agnostic security risks. These risks can be identified in many ways including Risk Assessments, reports from team members, industry trends, or as a result of compliance activities. There may be instances where an application's role is so significant to internal security controls that we may create risks specifically for that system. This will primarily be limited to GitLab.com as its use is pervasive in all that we do.

Out of Scope Unless they are related to a StORM risk (for example security compliance observations that span multiple systems), the following risk-types are not in scope for StORM:

1. Operational risks that are not security-related are out of scope (ex. accounting-specific risks)
1. Individual, system-specific security compliance observations (ex. inadequate password settings for a specific system)
1. Enterprise Risk Management (ERM) - internal only. Examples of ERM risks can be found on our Mitigating Concerns (internal only) handbook page.

Roles and Responsibilities

A risk governance structure has been put in place to outline the overall roles and responsibilities of individuals as it relates to StORM. The current governance structure is:

Role Responsibility

----- -----

Executive Risk Owner	- Accountable for driving treatment for one or more of GitLab's Top 5 Security Risks - Responsible for identifying one or more Risk Owners. Security Risk recommends identifying at least one Risk Owner per department involved in risk treatment - Responsible for approving the long-term risk treatment plan including the creation of KRs to
----------------------	---

associated treatment milestones identified by Risk Owners and the Security Risk Team
- Note that most Executive Risk Owners will be CEO + 2 (Senior Director or VP-level) and will be responsible for cross-department collaboration to drive risk reduction over time |

| Risk Owners | - Responsible for the creation of a long-term risk treatment plan including treatment milestones meant to reduce residual risk over time
- Accountable for executing risk treatment activities
- Responsible for collaborating with the Security Risk Team to ensure associated risk(s) and treatment status are reported periodically
- Note that most Risk Owners will be CEO + 3 (Senior Manager or Director level) |

| Security Risk Manager | This role is assigned per risk to a specific Security Risk team member. Expectations include:
- Maintains knowledge on the history, current-state, and direction of their risk
- Works with the risk owner or owners to ensure the risk status and treatment is documented
- Identifies, monitors, and participates in associated issues/MRs/epics/working groups that are relevant to their assigned risk
- Validates remediation activities
- Maps risks to relevant GCF controls, Root Cause Observation Epics, Security Compliance Tier 3 Observations, Field Security Study Observations, and other observations noted from security-impacting assessments (internal-only)
- Collaborates with Executive Risk Owner and Risk Owners to create and monitor long-term risk treatment plans|

| Security Risk Team | - Coordinates and executes StORM procedures including establishing risk appetite and conducting risk assessments
- Maintains the risk register to ensure accuracy and currency
- Acts in a Program Management capacity to support the tracking of risk treatment activities
- Coordinates peer validation testing after all risk remediation activities have been completed
- Periodically reports on the status of security operational risks
- Provides management level oversight of the StORM program, including continuing reviews of GitLab's Risk Register and acts as a point of escalation as needed
- Responsible for approving significant changes and exceptions to this procedure|

StORM Procedures

Establishing Risk Appetite and Tolerance

Tone at the Top: GitLab's StORM methodology uses a defined Risk Appetite and Risk Tolerance as primary drivers to determine which risks GitLab are willing to accept/take versus which risks we will need to mitigate. These thresholds are defined by Senior Leadership across the organization to ensure the Tone at the Top is aligned with the StORM program. Risk Appetite and Tolerance are reassessed year-to-year. This is done through an annual Risk Appetite Survey based on the ISO 31000 Risk Management Methodology. The survey is distributed to individuals operating in a Senior Leadership capacity with direct relations to Security Operations. The responses are averaged to arrive at an overall risk appetite and tolerance.

How GitLab Determines Risk Appetite

GitLab's security risk appetite is determined based on the total average priority order determined by senior leadership on the following risk strategy statements:

- GitLab should seek solutions to transfer risks to others whenever possible (risk taking vs

risk transfer)

- GitLab should balance pursuing opportunities that align with organizational objectives against the associated risks (organizational objectives)
- GitLab should respond to all risks impacting the organization, regardless of the level of impact (risk response approach)
- GitLab should respond to risks based on cost, management priorities, and ROI (risk response drivers)

Each risk strategy statement is ranked in order of priority from Highest priority risk strategy to Lowest priority risk strategy by senior leadership. GitLab utilizes the following risk appetite matrix:

| RISK APPETITE
| --- | --- | --- | --- | --- |
| RISK TAKING vs RISK TRANSFER | Aggressive risk taking is justified | Seek opportunities to transfer risks with pre-existing vendors as applicable (e.g. don't bring in a new vendor to transfer risks) | Take a balanced approach to risk taking vs risk transferring | Exercise caution and accept as little risk as possible by identifying risk transfer solutions |
| ORGANIZATIONAL OBJECTIVES | Willing to accept a large negative impact to the organization to pursue opportunities that align with objectives | Willing to accept some negative impact (e.g. LOW risks) to pursue opportunities that align with objectives | The potential for a negative impact vs objectives are given equal consideration when making a decision | The potential for a negative impact vs objectives are given equal consideration when making a decision |
| RISK RESPONSE APPROACH | All risks are acceptable as long as they do not impact our legal and regulatory obligations | Determine risk response options to help accept or reduce risk levels through internal initiatives | Risk remediation is favored over risk acceptance | Risks that cannot be effectively treated or transferred are avoided |
| RISK RESPONSE DRIVERS | No response action required for risks unless they may represent a contract or regulatory violation | Risk response actions take into consideration cost effectiveness, management priorities, and return on investment | Risk response actions emphasize the impact to security over the impact to strategic objectives | Risk response actions are always taken, regardless of cost effectiveness, management priorities, return on investment, and overall organizational objectives |

GitLab's Risk Appetite Matrix was formed through consideration of guidance set forth in NIST's SP 800-39 and SP 800-30 Rev. 1.

Scoring is performed by individuals operating in at least Senior Leadership capacity within GitLab and spans across multiple departments.

Translating GitLab's Security Risk Appetite to Risk Tolerance

Our risk appetite is translated to a tolerance which defines a range in which a risk score value is tolerable and does not require remediation or a risk acceptance, i.e., the risk response will be set to "monitor". Risk scores can range from 1 (lowest) to 30 (highest). The range is defined per Risk Appetite in the table below:

|Risk Averse|Risk Neutral|Risk Receptive|Risk Seeking|

	1-5	6-10	11-15	16-20

Risk scores above 20 (High or Critical risk rating) are considered too risky to be considered within tolerance. In other words, risks that are rated High and Critical must be treated.

Historical and Current Record of GitLab's Security Risk Appetite

Fiscal Year	Departments	Risk Appetite
FY24	All Departments	Risk Neutral
FY23	Engineering, Finance, and Legal	Risk Neutral
FY22	E-group, Engineering, Finance, and Legal	Risk Neutral
FY21	Engineering, Finance, and Legal	Risk Neutral

Risk Identification

Communication of Risks to the Security Risk Team

There are multiple ways the team can be engaged for risk:

- (Preferred) Submit a Risk Escalation issue on the StORM Repo.
- If the risk is identified within an issue, team members can tag the team directly by @ mentioning @gitlab-com/gl-security/security-assurance/security-risk-team on the issue or MR

When documenting risks, team members can leverage Observation Description guidance for existing issues/observations or risk drafting guidance.

Risks identified during risk assessments

The Security Risk Team may interview/survey GitLab team members operating in a leadership capacity at GitLab in order to identify security operational risks. Risks identified will always be framed in terms of threat sources and threat events, and then assessed against the likelihood of occurrence and the impact to GitLab if the risk event occurs. Additionally, these risks will be assessed against the current internal controls in place to determine the overall residual risk remaining.

In order to effectively identify, manage, and treat operational risks, GitLab has defined a set of threat source categories alongside specific risk factors and risk scoring definitions. Based on these threat sources, various stakeholders across the organization will be identified to participate in the Risk Identification phase. The identification of threat sources and events in relation to operational risks includes multiple considerations. These threat sources and events have been identified based on their potential to have an impact on mission critical objectives in relation to GitLab's operations.

Example Threat Sources and Events Considered

Threat Source	Example Threat Events
Adversarial	Fraud and theft, insider threat, malicious hacker, and malicious code

| Non-Adversarial | Errors and omission, loss of physical and infrastructure support (e.g. a natural disaster), exposure of sensitive information, changes to systems used to support the business, changes to external environments supporting GitLab, changes to GitLab's business model, or even changes in leadership |

Risk Drafting Guidance

StORM Program considerations include both risks (what might happen) and observations (what has happened/non-compliance). For guidance on writing observations, please refer to the Observation Management Procedure Handbook page.

When drafting a risk, start with a risk statement. This will represent the title of the Risk in our GRC system and is an attempt to condense the risk into a single sentence. In the spirit of low-context communication, avoid using single words or short phrases for the risk statement (ex. Supply Chain). As we largely deal with negative risks (vs. positive risks/opportunities), starting the statement with negative language like "Failure to", "Inadequate", "Incomplete", "Lack of", etc. is appropriate, but not required. As risks represent what might happen, use "may" before describing the negative effect it may have on the confidentiality, integrity, availability, security, and privacy of GitLab data. Example: Inadequate physical security controls may result in the loss of GitLab/Customer data and physical assets. The risk description should contain details related to the assets/resources at risk, the event that may occur, the source that would trigger the event (root cause), and the consequence (impact/loss) source.

Risk Factors and Risk Scoring

Risk rating/scoring is a favorite topic of risk management/decision support practitioners and thought-leaders. Scores are subjective and can be influenced by unconscious biases of those applying the scores. To help mitigate this risk, we report on risks and request feedback from management to help calibrate and ensure alignment on our highest priorities.

To score each risk, we leverage a formula based on the Likelihood of the risk event occurring and the Impact to GitLab if the event occurred. Likelihood and Impact scores directly determine the overall inherent risk to GitLab.

Determining Likelihood of initiation of a threat event

Qualitative	Score	Risk Level	Scoring Guidelines
6	CRITICAL	No expertise required to initiate a threat event	
5	VERY HIGH	Low level of expertise required to initiate a threat event	
4	HIGH	Some expertise required to initiate a threat event	
3	MEDIUM	Difficult to initiate a threat event, even with expertise	
2	LOW	Requires significant expertise to initiate a threat event	
1	VERY LOW	Theoretically impossible to initiate a threat event	

Determining the impact of a threat event

IMPACT	SCORE	Organizational Output	(time, quality, resources)	Brand	Reputation	Business	Continuity	Customers	&	Stakeholders	Legal	&	Regulatory	Financial
--------	-------	-----------------------	----------------------------	-------	------------	----------	------------	-----------	---	--------------	-------	---	------------	-----------

| :-----: | ----- | --- | ----- | ----- | ----- | ----- |

| VERY LOW (1) | Organizational output is impacted by less than 20% | Limited to reputational damage with no more than one customer within a fiscal period | Outages of non-critical systems that impact GitLab team members | Impact is limited to one customer and/or stakeholder | Breach of company policy occurring once in a fiscal period | Loss up to \$999 |

| LOW (2) | Organizational output is impacted by 30% - 40% | Confined to a limited number of parties (e.g. specific customers) and not publicized | Outages which result in the inability of GitLab to continue sales and finance operations longer than 72+ hours | Impact is limited to 2-3 customers and/or stakeholders | Breach of company policy twice within a fiscal period | Loss between \$1,000 and \$9,999 |

| MEDIUM (3) | Organizational output is impacted by 40% - 50% | Public domain publicity but limited to industry channels and not the broader public | Outages that impact GitLab's ability to do business across 3+ departments | Impact is limited to 4-5 customers and/or stakeholders | Breach of a regulatory and/or contractual obligation | Loss between \$10,000 and \$499,999 |

| HIGH (4) | Organizational output is impacted by 50% - 75% | Wide-spread publicity but limited parties are impacted | Outages that result in the loss of availability of GitLab for customers for less than 4 hours | Major impact to many customers and/or stakeholders | Regulatory censure and/or action taken against GitLab | Loss between \$500,000 and \$999,999 |

| VERY HIGH (5) | Organizational output is impacted by 75% or more | Widely publicized | Outages that result in the loss of availability of GitLab for customers for 4+ hours | Major impact to all customers and/or stakeholders | Public regulatory fines and/or major litigation against GitLab | Loss of \$1,000,000+ |

To arrive at a final impact score, the impact score of all impact categories is averaged.

Determining Inherent Risk vs Residual Risk

- Inherent Risk is the risk before considering any existing mitigations in place, such as existing controls, internal processes/procedures, etc. and is determined by the following formula:

$$> \text{Inherent Risk} = \text{Likelihood} \times \text{Impact}$$

- Residual risk is calculated in the same manner as inherent risk, but the likelihood and im